

IAM Access Risk Audit Report

Prepared by: Senior IAM & GRC Security Auditor

Classification: Confidential – Internal Audit Use Only

Review Scope: Automated Access Review – Identity & Access Management Controls

Executive Summary

The following findings were identified during an automated access review of organizational user accounts and entitlements. Four (4) access risk findings were detected across the Finance and Human Resources departments, comprising one (1) Critical, one (1) High, and two (2) Medium severity findings. These findings indicate material weaknesses in identity lifecycle management, privileged access governance, and dormant account controls. Immediate remediation is required for Critical and High findings, with timely resolution expected for Medium findings in accordance with organizational risk tolerance thresholds.

Detailed Findings

FINDING: [CRITICAL] — mgarcia

RISK:

A user account associated with mgarcia (Finance Department, Analyst role, Standard access) has been identified as belonging to a terminated employee who retains an active system record. The account has not been disabled or deprovisioned following the individual's separation from the organization. The continued existence of an active, authenticated identity for a former employee represents one of the most severe access control failures in identity lifecycle management. Terminated users no longer possess a legitimate business need for system access and are no longer bound by the organization's acceptable use policies, confidentiality agreements, or employment obligations. This condition creates an uncontrolled access vector that could be exploited — either by the former employee directly or by a malicious third party who obtains the credentials — to gain unauthorized entry into financial systems, exfiltrate sensitive data, or commit fraud.

IMPACT:

From a business perspective, the Finance Department handles sensitive financial records, transaction data, general ledger entries, and potentially payment card or banking information. An active terminated user account in this environment introduces substantial risk of unauthorized data access, financial fraud, or insider threat activity. The organization may face significant reputational and financial harm if this account is exploited.

From a compliance perspective, the failure to deprovision a terminated user's account upon separation constitutes a direct control deficiency under multiple regulatory frameworks. This finding may result in audit findings, regulatory citations, or examination failures for institutions subject to banking regulations (e.g., OCC, FFIEC) or healthcare oversight (e.g., HHS OCR). It also represents a failure of the organization's Identity Lifecycle Management program and may trigger breach notification obligations if unauthorized access is subsequently discovered.

REMEDIATION:

1. Immediate Action (Within 24 Hours): Disable and lock the mgarcia account across all systems, directories (e.g., Active Directory, LDAP), and downstream applications. Revoke all associated session tokens, API keys, and credentials.
2. Short-Term (Within 5 Business Days): Conduct a forensic access log review to determine whether the account has been accessed since the user's termination date. Document findings and escalate to the Incident Response team if any unauthorized access is confirmed.
3. Process Remediation (Within 30 Days): Perform a full audit of the offboarding process to identify how this account remained active post-termination. Implement automated deprovisioning workflows triggered by HR system separation events to ensure same-day or next-business-day account disablement for all future terminations.
4. Long-Term: Implement a monthly reconciliation control between HR termination records and Active Directory/IAM system account status to detect future instances of this failure.

FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — requires organizations to remove or disable accounts when individuals are terminated; PS-4 (Personnel Termination) — mandates timely revocation of system access upon employee separation.
- PCI-DSS v4.0: Requirement 7.2 and Requirement 8.2.6 — require that access for terminated users is immediately revoked and that all inactive or unauthorized accounts are removed.
- SOC 2 (Trust Services Criteria): CC6.2 — requires that logical access is removed when no longer needed; CC6.3 — addresses user registration and deregistration processes including termination procedures.
- HIPAA Security Rule: 45 CFR §164.308(a)(3)(ii)(C) — Termination Procedures implementation specification requires covered entities to establish procedures for terminating access to ePHI upon workforce member separation.

FINDING: [HIGH] — rlee

RISK:

User rlee (Finance Department, Contractor role) has been identified as holding Privileged access, a level of entitlement that significantly exceeds what is appropriate for a non-permanent, third-party workforce member. Contractors, by their nature, represent an elevated identity risk profile: they operate under limited organizational oversight, are not subject to the same background screening and employment controls as full-time employees, and their engagements are time-bound and purpose-specific. The assignment of privileged access — which typically encompasses administrative rights, elevated system permissions, or access to sensitive financial data and controls — to a contractor account violates the principle of least privilege and creates an undue risk of unauthorized data exposure, system manipulation, or privilege abuse. This finding is of particular concern within the Finance Department, where privileged users may have the ability to modify financial records, approve transactions, or access audit logs.

IMPACT:

From a business perspective, a contractor with privileged access to financial systems could — whether through negligence, error, or malicious intent — alter financial records, access proprietary financial data, or interfere with internal controls. The risk of supply chain or third-party compromise is also heightened, as contractor credentials are a well-documented attack vector exploited in high-profile breaches. The absence of least-privilege enforcement also undermines the organization's ability to maintain segregation of duties.

From a compliance perspective, granting privileged access to contractors without documented business justification, formal approval, and compensating controls constitutes a control gap under all major regulatory frameworks. For banking clients, this finding may be flagged during FFIEC IT examinations. For healthcare clients, this represents a potential HIPAA Security Rule violation regarding workforce access controls. This finding may also adversely affect SOC 2 Type II audit outcomes if not remediated prior to the audit period's close.

REMEDIATION:

1. Immediate Action (Within 48 Hours): Review and document the specific privileged entitlements assigned to rlee. Engage the account owner and sponsoring business unit to obtain a formal business justification for the elevated access level.
2. Short-Term (Within 10 Business Days): If a valid business justification cannot be provided, immediately downgrade rlee's access to the minimum level required to fulfill their contracted responsibilities (Standard or role-specific access). Revoke all privileged entitlements that are not documented and approved.
3. Compensating Controls (If Privileged Access Is Justified): If elevated access is deemed operationally necessary, implement the following compensating controls: (a) Just-In-Time (JIT) privileged access provisioning; (b) enhanced session monitoring and logging of all privileged activity; (c) multi-factor authentication (MFA) enforcement for privileged sessions; (d) time-limited access with automatic expiration aligned to the contract term.
4. Process Remediation (Within 30 Days): Implement a Privileged Access Management (PAM) policy that explicitly prohibits the assignment of standing privileged access to contractor accounts without CISO or executive-level approval and formal risk acceptance documentation.

FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — requires access assignments to reflect least privilege and business need; AC-6 (Least Privilege) — mandates that users are granted only the minimum access rights required; AC-17 (Remote Access) — applicable if contractor access is remote; IA-2 (Identification and Authentication) — requires MFA for privileged accounts.

- PCI-DSS v4.0: Requirement 7.2.1 — requires that access rights are assigned based on job classification and function; Requirement 8.2.2 — mandates that group, shared, or generic accounts are not used and that individual accountability is maintained for privileged activity.

- SOC 2 (Trust Services Criteria): CC6.3 — requires that access is granted based on authorized roles with appropriate review; CC6.6 — addresses logical access restrictions for third parties and contractors.

- HIPAA Security Rule: 45 CFR §164.308(a)(3) — Workforce Access Management requires that access to ePHI be granted only to authorized workforce members with documented business need; 45 CFR §164.308(b) — Business Associate provisions are relevant if the contractor handles ePHI.

FINDING: [MEDIUM] — tjones

RISK:

User tjones (HR Department, Manager role, Standard access) has been identified as a dormant account with no recorded login activity in excess of 90 days. Dormant accounts — those that remain active and enabled despite prolonged periods of inactivity — represent a persistent and often overlooked vulnerability within an organization's access control environment. An unused account may indicate that the user has changed roles, taken extended leave, or is no longer actively using the system, yet the account retains full credentials and entitlements. Such accounts are attractive targets for unauthorized access, as they are less likely to be monitored and credential anomalies may go undetected. In the HR Department, where the role carries Manager-level privileges, the account likely has access to sensitive personnel records, compensation data, benefits information, and potentially Social Security Numbers or other personally identifiable information (PII), amplifying the risk profile of this dormant condition.

IMPACT:

From a business perspective, an unmonitored dormant account with access to HR systems creates a significant risk of unauthorized exposure of employee PII and confidential HR data. If credentials are compromised — through phishing, credential stuffing, or password reuse — an attacker could access sensitive workforce information with limited likelihood of detection due to the account's inactivity baseline.

From a compliance perspective, the retention of active but unused accounts violates least-privilege and access recertification requirements under multiple frameworks. For healthcare organizations, access to employee records containing health information may trigger HIPAA considerations. This finding may be cited as a control deficiency in SOC 2 audits and NIST-aligned security assessments.

REMEDIATION:

1. Immediate Action (Within 10 Business Days): Contact the account owner (tjones) and their department head to verify current employment status, role, and whether access to the system remains operationally necessary.
2. Short-Term: If the user confirms an ongoing need, require immediate re-authentication and password reset before restoring active access status. If no business need is confirmed, disable the account immediately.
3. Process Remediation (Within 30 Days): Implement an automated dormant account detection control that flags accounts with no login activity beyond a defined threshold (recommended: 60–90 days) and initiates an automated review workflow. Accounts that are not recertified within the review window should be automatically disabled.
4. Long-Term: Incorporate dormant account review into the quarterly access recertification cycle, with mandatory manager attestation for all accounts approaching the inactivity threshold.

FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2(3) — requires automated disabling of inactive accounts after an organizationally defined period; AC-2(4) — mandates automated audit of account management actions.
- PCI-DSS v4.0: Requirement 8.2.6 — requires that inactive user accounts are either removed or disabled within 90 days of inactivity.
- SOC 2 (Trust Services Criteria): CC6.2 — requires that access is removed or modified when no longer necessary; CC6.3 — addresses periodic review and recertification of user access rights.
- HIPAA Security Rule: 45 CFR §164.308(a)(5)(ii)(C) — Log-in Monitoring implementation specification; 45 CFR §164.312(a)(2)(i) — Unique User Identification requires that access credentials are maintained and monitored for authorized workforce members only.

FINDING: [MEDIUM] — hkim

RISK:

User hkim (Finance Department, Contractor role, Standard access) has been identified as a dormant account with no recorded login activity in excess of 90 days. This finding is of compounded concern given that the user is a contractor — a non-permanent workforce member whose system access should be inherently time-limited and closely tied to active engagement with the organization. A contractor account that has remained inactive for 90 or more days strongly suggests that the individual's engagement may have concluded or been suspended, yet the account has not been deprovisioned. Within the Finance Department, even Standard-level access may grant the ability to view sensitive financial data, transaction records, or customer account information, making the persistence of this unused account a material access control gap.

IMPACT:

From a business perspective, contractor accounts carry an inherently higher risk profile than employee accounts due to reduced organizational oversight and the transient nature of the engagement. A dormant contractor account in the Finance Department that has not been reviewed or deprovisioned may indicate a broader failure in third-party access lifecycle management. If the contractor's engagement has ended, this account represents unauthorized residual access. If the engagement is ongoing, the inactivity itself warrants investigation to determine whether access is still necessary.

From a compliance perspective, failure to manage contractor account lifecycles — including timely deprovisioning upon contract expiration — is a frequently cited finding in financial services and healthcare audits. Regulatory examiners expect organizations to demonstrate that third-party access is actively governed, time-bound, and subject to the same recertification standards as internal user accounts.

REMEDIATION:

1. Immediate Action (Within 10 Business Days): Verify the current contract status of hkim with the sponsoring business unit and procurement/vendor management team. Confirm whether an active Statement of Work (SOW) or contract is in place and whether system access is still required.
2. Short-Term: If the contract has expired or access is no longer required, immediately disable and deprovision the account. If the engagement is ongoing and access remains necessary, require a password reset and re-authentication event before restoring active status.
3. Process Remediation (Within 30 Days): Implement automated access expiration controls that tie contractor account validity to contract end dates sourced from the organization's vendor management or procurement system. All contractor accounts should carry a hard expiration date that triggers automatic disablement unless explicitly renewed with documented approval.
4. Long-Term: Establish a Contractor Access Governance program that includes: (a) mandatory access reviews at the midpoint and conclusion of each contract; (b) 30-day, 60-day, and 90-day inactivity alerts with automated escalation to the account sponsor; (c) integration between vendor management records and the IAM platform to enforce access lifecycle alignment.

FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — requires management of contractor accounts with defined activation and expiration conditions; AC-2(3) — mandates automated disabling of inactive accounts; SA-9 (External System Services) — requires oversight of third-party access to organizational systems.
- PCI-DSS v4.0: Requirement 8.2.5 — requires that all inactive accounts are removed or disabled within 90 days of inactivity; Requirement 12.8 — requires that third-party access is managed, monitored, and subject to policy requirements.
- SOC 2 (Trust Services Criteria): CC6.2 — requires removal or modification of access when no longer appropriate; CC9.2 — addresses vendor and third-party risk management, including access governance for service providers and contractors.
- HIPAA Security Rule: 45 CFR §164.308(a)(3)(ii)(B) — Workforce Clearance Procedure; 45 CFR §164.308(b)(1) — Business Associate Contracts and Other Arrangements, applicable where contractor access involves ePHI; 45 CFR §164.312(a)(2)(i) — Unique User Identification requirements for all workforce members including contractors.

Summary Risk Table

| Finding | User | Department | Severity | Issue | Immediate Action Required |

|---|---|---|---|---|---|

| 1 | mgarcia | Finance | ■ Critical | Terminated user — active account | Yes — Within 24 Hours |

| 2 | rlee | Finance | ■ High | Contractor with privileged access | Yes — Within 48 Hours |

| 3 | tjones | HR | ■ Medium | Dormant account — 90+ days inactive | Yes — Within 10 Business Days |

| 4 | hkim | Finance | ■ Medium | Dormant contractor — 90+ days inactive | Yes — Within 10 Business Days |

Auditor Recommendations — Systemic Controls

Beyond the individual findings above, the audit team recommends the following systemic IAM control enhancements to address the root causes observed across these findings:

1. Automate the Jo